Описание кейса №1
Разработка уязвимого сервиса

Подробная информация о кейсе представлена на сайте hosts.standoff365.com

Почувствуй себя в роли тренера для комьюнити экспертов в ИБ — разработай уязвимый сервис, на котором будут качать свои навыки исследователи безопасности

Что за уязвимые сервисы?

Это специально разработанные виртуальные машины с преднамеренно заложенными уязвимостями в сервисах.

Они используются для тренировки хакеров и специалистов по кибербезопасности, позволяя им изучать и отрабатывать навыки обнаружения и эксплуатации уязвимостей в контролируемой и безопасной среде.

Критическое событие — это что?

Событие, возникающее в результате кибератаки, которое наносит организации серьёзный ущерб и негативно влияет на её деятельность. Например, сбой в системе регистрации пассажиров, слив персональных данных в сеть.

В каждом уязвимом сервисе — разработанной виртуальной машине — может быть заложено одно или несколько критических событий.

Где будут использоваться сервисы?

Лучшие уязвимые сервисы будут размещены на онлайн-полигоне Standoff Hackbase — виртуальной инфраструктуре с реалистичными копиями ИТ-систем из разных отраслей.

На онлайн-полигоне есть разные отраслевые сегменты — инфраструктуры, в которых воссозданы технологические и бизнес-процессы из разных сфер экономики.

Примеры сервисов, которые можно создавать

Веб-ресурсы

- **Онлайн-библиотека** с уязвимостью, приводящей к утечке конфиденциальных данных
- **Служба курьерской доставки** с уязвимостью, позволяющей завладеть чужими посылками путём подмены адресов получателей

Системные уязвимости

- **Windows и Active Directory** с уязвимостями, позволяющими получить несанкционированный доступ к ресурсам сети
- **Reverse engineering** — область, в которой нужно анализировать и эксплуатировать уязвимости в программном обеспечении для понимания работы алгоритмов информационной системы и поиска путей для нарушения их работоспособности

Как сдать сервис

Придумай и разработай уязвимый сервис

У каждого уязвимого сервиса образовательная цель, поэтому заложенные уязвимости должны учить пользователя новому, развивать его навыки и расширять кругозор. Важно:

- затрагивать проблематику безопасности — от общих аспектов до конкретных ситуаций, часто возникающих в повседневной жизни;
- тщательно прорабатывать вектор реализации критического события, чтобы он был логичен и понятен для пользователя. Цель — исключить любые недоразумения в определении пути развития атаки (избежать любых бессмысленных «кроличьих нор»);
- ставить себя на место хакера, чтобы понимать, где он будет искать уязвимости. Применяй нестандартные и сложные решения, чтобы твой сервис был максимально полезен комьюнити для обучения кибербезопасности.

При создании сервиса обязательно сверяйся с Требованиями, чтобы твоя работа не пошла в стол.

Проверь сервис

Перед отправкой сервиса команде Standoff выполни следующие шаги:

1. Сделай первичную проверку. Проведи её в режиме black box, чтобы оценить логичность заложенных шагов вектора.
2. Проверь, есть ли в сервисе незаложенные уязвимости.
   Если они есть и сложность уязвимости соответствует сложности хоста и укладывается в легенду, согласуй её наличие с командой Standoff на чек-поинтах. При несоответствии сложности предоставленной виртуальной машины согласуй изменение её сложности на платформе с командой Standoff.
3. Оцени отказоустойчивость хоста. Должна быть возможность откатить состояние виртуальной машины до изначального, после чего она должна работать без дополнительных манипуляций.

Скачай и заполни шаблон

Важно прислать всю информацию про разработанный сервис именно в нашем шаблоне. Чтобы ничего не забыть, после заполнения сверь содержание по чек-листу:

- Полное пошаговое руководство с описанием реализации вектора и получения обоих флагов в формате Markdown.
- Описание, где располагаются флаги и как их автоматически обновить. Желательно, чтобы обновление работало с помощью команд: cmd, bash, SQL и т. п.
- Все учетные данные пользователей
- Описание всех важных компонентов и процессов уязвимой машины, участвующих в векторе атаки
- Описание используемых портов
- Исходный код скриптов, веб-приложений, конфигураций
- Описание правил брандмауэра (при наличии)

СКАЧАТЬ ШАБЛОН

Оценивание

Уровень сложности **(от 0 до 3)**	Оценка уровня сложности задания, насколько оно соответствовало заявленному и насколько его выполнение требовало усилий и знаний.
Техническое качество **(от 0 до 3)**	Оценка того, насколько обоснованно и корректно были использованы технологии, методы и инструменты в ходе создания сервиса, насколько чист код (если код написан в ходе разработки сервиса), соответствие техническим требованиям.

Удобство интеграции и количество доработок для внедрения **(от 0 до 3)**	Оценка того, насколько легко можно интегрировать предложенное решение или атаку в реальный киберполигон и сколько доработок потребуется для его полноценного использования.
Качество легенды уязвимого сервиса **(от 0 до 3)**	Оценка того, насколько правдоподобна и проработана легенда уязвимого сервиса, глубина проработки сервиса, имитация настоящего поведения сервиса в контексте легенды.
Оригинальность вектора атаки и его уникальность **(от 0 до 3)**	Оценка того, насколько оригинален и уникален предложенный вектор атаки, отличается ли он от стандартных, классических атак, насколько он логичен в контексте именно этой тачки.

Ваш результат

Мы ожидаем от вас по итогам хакатона:

- Опубликованный код в репозиторий на Git
- Презентация для питч-сессии
- Заполненный шаблон и подробнейший райтап в нем
- Желательно, развернутая демо-версия на ваших мощностях
- Оцененная вами сложность вашего вектора

Требования к сервисам

Приоритетной является версия на сайте
https://hosts.standoff365.com/#requirements

Общие

Про сам сервис

- Образ сервиса: совместим с VMware Workstation 16.2 или ESXi 7.0
- Версии ОС: последняя на момент разработки сервиса
- Патчи для ОС: актуальные на момент разработки. Исключение — если не нужен конкретный патч
- Возраст уязвимостей: не старше 12 месяцев. Отталкивайся от даты появления эксплойта или PoC
- Порты: закрыты. Исключение: можно оставлять открытыми, если они нужны для работы сервиса или реализации вектора атаки
- Неиспользуемые устройства и диски должны быть отключены
- Контент, генерируемый пользователями при реализации вектора, должен автоматически удаляться через тот промежуток времени, которого хватит для прохождения шага
- «Заглушки» должны явно быть заглушками, а не возвращать ошибки 500, 403 и т. п.
- Используйте только свободное ПО без срока действия. Использовать коммерческое ПО запрещено даже при наличии демоверсий
- Проектируйте сервисы так, чтобы хакеры «не толкались». Например, плохая практика — одна учетная запись на всех с вектором сброса пароля

Про хосты

- Язык составных частей уязвимого хоста: английский
- Образ хоста: в формате OVA с установкой VMware Tools
- После окончательной настройки хоста воспользуйтесь инструментами WinPEAS / LinPEAS для обнаружения незаложенных уязвимостей и исправьте их

Про контент

- Максимально реалистичный и совпадающий с тем, как конкретный сервис выглядит и функционирует в обычной жизни
- В случае внедрения подсказок они должны вписаться в легенду уязвимой виртуальной машины

Про брутфорс

- Все элементы, подлежащие брутфорсу, должны перебираться не дольше 10 минут. Используйте пароли из общеизвестных словарей, например Seclists

- Избегайте векторов с брутфорсом. Отключайте рейт-лимит запросов
- При установке паролей, которые не подлежат брутфорсу, используйте сервис xkpasswd. Пример формата: 55-floor-EXACTLY- form-64

Для хостов с UNIX-подобными системами

- Имя хоста на системе должно совпадать с названием уязвимого сервиса на платформе
- Ресурсы, требуемые для работы виртуальной машины, не должны превышать следующих значений: 20 ГБ ROM, 4 ГБ RAM, 2 процессора. При наличии крутой идеи, для которой нужно больше мощностей, напиши нам hosts@standoff365.com
- Чтобы предотвратить появление подсказок в файлах истории, необходимо отправлять их в /dev/null. Например: bash_history, .mysql_history, .viminfo, .zsh_history, .bash_eternal_history и т. п.), если это не нужно для реализации вектора

Для Windows-хостов

- Имя хоста должно совпадать с названием уязвимого сервиса на платформе
- Имя домена должно совпадать с именем хоста (***.stf)
- Ресурсы, требуемые для работы виртуальной машины, не должны превышать следующих значений: 40 ГБ ROM, 4 ГБ RAM, 4 процессора
- Отключайте ведение истории команд, если это не нужно для реализации вектора
- Используйте бесплатные пробные версии

Уровни сложности сервиса

Сложность	Шагов до реализации критического события	Содержание
Легкий	2–3	• Могут быть подсказки на всех шагах • Без бинарных уязвимостей • CVE с существующими эксплойтами • Простой сценарий
Средний	3–4	• Могут быть подсказки на первых шагах • Могут быть простые бинарные уязвимости • CVE с POC или простой кастомной эксплуатацией • Средний сценарий
Сложный	4–5	• Больше кастомных эксплуатаций • Объединение нескольких уязвимостей • Больше enum • Сложный сценарий
Очень сложный	5+ или 3–4 очень сложных	• Без подсказок • Нет готовых эксплойтов и POC • Объединение нескольких уязвимостей • Сложный и запутанный сценарий

А вот этого не надо ❌

- Нецензурная лексика, оскорбления и резонирующие темы, например политика и религия
- «Кроличьи норы» без какой-либо цели
- ПО, которое сильно нагружает хост, если того не требует вектор. Например, nginx предпочтительнее Apache2
- Ссылки на внешние ресурсы и использование внешних компонентов за пределами локальной сети
- Закладка бэкдоров «для своих»
- Использование логотипов и названий существующих компаний. Например, нельзя делать ресурс, похожий на X или VK с использованием его лого и названия